

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 1 頁，共 9 頁

單選題 50 題（佔 100%）

B	1. 下列何者「不」是私有網路位址（Private IP）？ (A) 10.0.0.1 (B) 169.254.2.210 (C) 172.31.5.128 (D) 192.168.10.220
D	2. 關於網路設備與 OSI 參考模式，下列敘述何者正確？ (A) 中繼器（Repeater）是在資料鏈結層（Data Link Layer） (B) 橋接器（Bridge）是在實體層（Physical Layer） (C) 閘道器（Gateway）是在網路層（Network Layer） (D) 路由器（Router）是在網路層（Network Layer）
C	3. 設定密碼時需注意許多原則規範以免太容易被攻擊者猜出，下列何者是較好的密碼設定？ (A) QAZWSXEDCRT (B) 56781344 (C) qWA\$s&1!aBap (D) helloworld
C	4. 下列何種應用層的通訊協定，在傳輸的過程中並未對內容進行加密處理？ (A) SSH (B) TLS (C) SMTP (D) HTTPS
C	5. 下列何者「不」是微軟網路芳鄰常見使用 Port？ (A) 137 (B) 139 (C) 123 (D) 445
C	6. 下列何種防火牆，因僅針對封包標頭進行檢查，並無針對封包資料進行檢查，可能難以抵禦大量封包的分散式攻擊？ (A) 狀態檢查防火牆（Stateful Inspection Firewall） (B) 應用代理閘道防火牆（Application-proxy Firewall） (C) 封包過濾防火牆（Packet-filtering Firewall） (D) 混合型防火牆（Hybrid Firewall）
B	7. 死亡之 Ping（Ping of Death, PoD）是針對開放式系統互聯模型（Open System Interconnection Model, OSI Model）的何層攻擊？

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 2 頁，共 9 頁

	(A) Layer 2 資料連接層 (Data-Link Layer) (B) Layer 3 網路層 (Network Layer) (C) Layer 4 傳送層 (Transport Layer) (D) Layer 7 應用層 (Application Layer)
A	8. TCP/IP 通訊協定中，負責提供網路服務給應用程式的是何層的工作？ (A) 應用層 (B) 傳輸層 (C) 網路層 (D) 會議層
A	9. 為了電子郵件的通訊安全，可以使用下列何者？ (A) TLS (B) SNMP (C) SMTP (D) SLIP
A	10. TCP 三向交握 (Three-way Handshake) 的順序為下列何者？ (A) SYN, SYN/ACK, ACK (B) SYN, ACK, SYN (C) SYN, SYN, SYN (D) ACK, SYN, SYN
B	11. 使用 IPSec 傳輸模式 (Transport Mode) 的主要保護特性為何？ (A) 只對封包標頭加密保護 (B) 只對資料本身 (Payload) 加密保護 (C) 整個封包 (標頭和資料本身) 均被加密保護 (D) 必須根據 IKE 參數決定加密範圍
D	12. 關於資料在傳輸層使用 TLS 協定進行資料的保護，下列敘述何者「不」正確？ (A) 透過加密而能確保資訊的私密性 (B) 藉由加密來確保訊息的完整性 (C) 經由數位授權提供資料的真實性 (D) 經由公開金鑰進行加解密的過程
C	13. 若要僅有收件者能開啟，並確認內容未遭篡改的信件，下列敘述何者正確？ (A) 信件以雜湊 (Hash) 演算後，以寄件者的私密金鑰 (Private Key) 加密後寄出

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 3 頁，共 9 頁

	(B) 信件以雜湊 (Hash) 演算後，以收件者的私密金鑰 (Private Key) 加密後寄出 (C) 信件以雜湊 (Hash) 演算後，以收件者的公開金鑰 (Public Key) 加密後寄出 (D) 使用收件者的公開金鑰 (Public Key) 加密信件
A	14. 若 CPU 執行時間切割為一個固定的時間，分配給每一個程式，當固定之時間一到，隨即讓出 CPU 的時間給下一個程式使用，此為下列何種作業系統？ (A) 分時系統 (B) 多工系統 (C) 即時系統 (D) 多處理機系統
C	15. 當某一應用程式向作業系統要求記憶體之空間，作業系統亦為此應用程式指定一塊區域，當使用完畢後，此應用程式並沒有通知作業系統，故此區域無法釋放做其他用途，此現象稱為？ (A) 記憶體暫存 (Memory Register) (B) 記憶體注入 (Memory Injection) (C) 記憶體洩漏 (Memory Leaks) (D) 記憶體映像 (Memory Mapping)
A	16. 若要從 Linux 系統中 dump 出密碼的 Hash 值，需存取下列何種檔案？ (A) /etc/shadow (B) /etc/issue (C) /etc/hosts (D) /etc/passwd
B	17. 於 Linux 作業系統中，SELinux (Security-Enhanced Linux) 為何種存取控制模型的實作？ (A) DAC (Discretionary Access Control) (B) MAC (Mandatory Access Control) (C) RBAC (Role-Base Access Control) (D) NonDAC (Non-Discretionary Access Control)
A	18. 提權 (Privilege Escalation) 的用意為下列何者？ (A) 利用 exploit 提升使用者權限至 root (B) 隱藏入侵軌跡 (C) 刪除使用者帳號

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 4 頁，共 9 頁

	(D) 登入遠端桌面
D	19. 下列程式碼片段存在安全瑕疵，請問下列何者可達成 SQL Injection 攻擊？ String query = "SELECT * FROM accounts WHERE custID='" + request.getParameter("id") + "'"; (A) id = 0 OR 1 (B) custID = 1 or 1 (C) '1'='1' (D) ' or '1'='1'
A	20. 在連線網頁時，Client 端與 Server 端中間的資料傳輸常會使用下列何種協議方式進行保護傳輸？ (A) TLS (B) AES (C) RSA (D) DES
A	21. 攻擊者針對程式設計缺陷，在某個資料超過了處理程式限制的範圍時，破壞程式執行、趁著中斷之際取得程式或是系統的控制權，進而入侵系統，竊取資料，甚至造成主機當機的現象，是下列何種攻擊手法？ (A) 緩衝區溢位 (Buffer Overflow) (B) SQL 注入 (SQL Injection) (C) 重送攻擊 (Replay Attack) (D) 阻斷式攻擊 (Denial of Service Attack)
A	22. 關於密碼潑灑 (Password Spraying)，下列敘述何者正確？ (A) 用單一弱密碼，嘗試登入所有帳號 (B) 蒐集常見的密碼，放入字典，嘗試登入系統 (C) 利用外洩的帳號與密碼組合，嘗試登入系統 (D) 使用所有可能密碼組合，嘗試登入系統
B	23. 某程式設計師撰寫網頁應用程式的密碼雜湊系統 (Password Hashing System)，下列為程式中雜湊函式所產生的過程與結果： hash (password1 + 07C98BFE4CF67B0BFE2643B5B22E2D7D) = 10B222970537B97919DB36EC757370D2 hash (password2 + 07C98BFE4CF67B0BFE2643B5B22E2D7D) = F1F16683F3E0208131B46D37A79C8921 請問此程式設計師犯了何種錯誤？ (A) 雜湊值太短

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 5 頁，共 9 頁

	(B) 重覆使用 Salt (C) Salt 太短 (D) 雜湊演算法有漏洞
A	24. 下列何者為防禦跨站請求偽造（Cross-Site Request Forgery, CSRF）攻擊的最佳方式？ (A) 使用驗證碼（CAPTCHA） (B) 輸入參數黑名單過濾 (C) 輸入參數白名單過濾 (D) 輸入參數長度過濾
D	25. 下列何者「不」是不安全程式碼所會造成的問題？ (A) 注入（Injection）攻擊 (B) 跨站指令碼（Cross-Site Scripting, XSS）攻擊 (C) 跨站請求偽造（Cross-Site Request Forgery, CSRF） (D) 網路釣魚（Phishing）
C	26. 關於單元測試（Unit Test）與功能測試（Function Test），下列敘述何者較「不」正確？ (A) 單元測試主要測試單一單元是否運作正常 (B) 功能測試主要測試是否符合功能需求 (C) 單元測試與功能測試應由軟體品保工程師進行 (D) 功能測試的複雜度較單元測試為高
D	27. 關於網站常見的跨站指令碼（Cross-site scripting, XSS）攻擊，下列何者「不」能透過此一攻擊達成？ (A) 盜取使用者的網站帳號密碼 (B) 進行網站掛馬 (C) 取得 Cookie 資訊 (D) 取得任意資料庫內 DATA
C	28. 惡意程式分析常使用下列何種方法防禦進階的攻擊？ (A) 動態分析 (B) 靜態分析 (C) 沙盒分析 (D) 原始碼分析
B	29. 駭客可以透過網路記錄（Cookies）竊取個人資料，請問原因為下列何者？ (A) 因為 Cookies 是一種惡意的間諜程式 (B) 因為 Cookies 可能會記錄使用者瀏覽網頁的資訊、帳號與密碼

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 6 頁，共 9 頁

	(C) 因為 Cookies 是一種新的網路技術 (D) 因為 Cookies 是一種新的病毒
D	30. 下列何種漏洞通常無法被漏洞掃描工具偵測與辨識出來？ (A) 區域漏洞（Local Vulnerabilities） (B) 稀疏漏洞（Sparse Vulnerabilities） (C) 沙盒漏洞（Sandbox Vulnerabilities） (D) 零時差漏洞（Zero-Day Vulnerabilities）
C	31. 下列何者是資安人員常用來找出作業系統漏洞的工具？ (A) ping (B) scapy (C) OpenVAS (D) MBSD
A	32. 關於勒索軟體（Ransomware），下列敘述何者「不」正確？ (A) 所有防毒軟體可防禦已知/未知勒索軟體，避免遭受加密攻擊 (B) 部分勒索軟體已有工具可進行解密 (C) 勒索軟體常使用主流加密演算法（如：RSA 與 AES），將使用者文件、系統檔案加密後要求支付贖金 (D) 比特幣因去中心化與匿名等特性而無法有效追蹤流向，常為勒索軟體要求支付使用
C	33. 差異備份、增量備份、完整備份，此三種備份方式的備份速度，由快到慢依次為下列何者？ (A) 完整備份、差異備份、增量備份 (B) 差異備份、增量備份、完整備份 (C) 增量備份、差異備份、完整備份 (D) 完整備份、增量備份、差異備份
D	34. 公司內部使用 DVD 光碟儲存機密資料，下列何種資料清除方式可以較安全地將資料銷毀，防止資料洩漏？ (A) 使用 Delete 命令 (B) 消磁 (C) 安全抹除（ATA Secure Erase） (D) 實體破壞
D	35. 關於密碼儲存與保護，下列敘述何者為最佳實務？ (A) 密碼明文（Plaintext）儲存即可，無需進行加密 (B) 密碼應使用對稱式加密（Symmetric encryption）儲存 (C) 密碼應使用非對稱式加密（Asymmetric encryption）儲存 (D) 密碼加鹽後（Password salting），再儲存其雜湊與鹽值

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 7 頁，共 9 頁

C	36. 若公司營運系統伺服器內有三顆硬碟作 RAID 5，並且備份機制中規劃每週五 23:00 進行完整備份（Full Backup），其餘每天 23:00 進行增量備份（Incremental Backup）已持續運行半年狀況很好，無奈於本週一 11:00 時伺服器其中一顆硬碟發生故障，請問應採取下列何種處理方式？ (A) 將上週五的 Full Backup 磁帶回存，再將六、日的增量備份磁帶回存 (B) 將上週五的 Full Backup 磁帶回存，再將週日的備份磁帶回存 (C) 更換有問題的硬碟 (D) 更換有問題的硬碟，並將上週五的 Full Backup 磁帶回存，再將六、日的增量備份磁帶回存
D	37. 關於 SAN（Storage Area Network）及 NAS（Network Attached Storage），下列敘述何者「不」正確？ (A) SAN 及 NAS 都是提供伺服器與儲存設備間高速連結 (B) SAN 透過光纖通道或 IP 網路與伺服器作連結 (C) NAS 可透過 IP 網路與伺服器連結 (D) NAS 應其應用彈性較大故價格較 SAN 昂貴
C	38. 關於系統日誌的管理與分析，下列敘述何者較「不」正確？ (A) 應選擇適當的整合式 Log 管理工具，並且測試確認是否能快速查詢分析 (B) 可以考慮將日誌加密儲存，以避免資料遭到竄改 (C) 日誌的資料量不大，所以不需考慮傳輸時頻寬 (D) 最好能夠定義哪些事件是需要優先監控和分析的
A	39. 某組織之系統開發人員於開發系統時，均各自將其所開發之不同系統依據其個人喜好設定日誌檔結構，請問若系統管理人員欲針對這些系統開發人員所設計之日誌檔進行管理，則該將這些日誌檔如何處理最為合適？ (A) 正規化 (B) 分散化 (C) 依設計原意不變 (D) 集中化
A	40. 在 Web 服務器日誌中，若看到使用操縱變量的攻擊者使用“dot-dot-slash（../）”排列和其他變化，如： http://www.juggyDoy.com/GET/process.php/../../../../etc/passwd. ，請問此為下列何種攻擊手法？

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 8 頁，共 9 頁

	(A) 目錄遊走 (Directory Traversal) (B) SQL 注入 (SQL Injection) (C) 跨站指令碼攻擊 (Cross-Site Scripting, XSS) (D) 文件注入 (Content Injection)
C	41. 關於留存日誌之系統、設備等的時間同步 (Clock Synchronization)，下列敘述何者最正確？ (A) 無需進行時間同步 (B) 系統才需進行時間同步，網路設備不需要 (C) 可設定所有系統、設備，先向同一主機進行校正，再由該主機對外時間源進行校正 (D) 不同系統、設備，應分別向外部不同時間源進行時間校正，以分散風險
C	42. 一般在進行資安日誌分析時，若想分析 Linux 系統中使用者的登入歷史紀錄，應蒐集下列何種檔案？ (A) /var/log/messages (B) /etc/login.defs (C) /var/log/secure (D) /var/log/dmesg
C	43. 下列何者「不」是常見的雲端運算的服務型式？ (A) 軟體即服務 (Software as a Service, SaaS) (B) 平台即服務 (Platform as a Service, PaaS) (C) 知識即服務 (Knowledge as a Service, KaaS) (D) 基礎架構即服務 (Infrastructure as a Service, IaaS)
C	44. 某用戶需要 1TB 的雲端儲存空間，因此服務提供商可能從單一的實體硬碟，或是串接而成的陣列系統，並從不同的地點透過網路來提供所需的容量，使用者並不需要知道資源實際的所在位置，即可順利地使用。請問上述符合何種雲端服務的關鍵特徵？ (A) 按照需求自行調配 (B) 廣泛的網路存取方式 (C) 虛擬化的資源池 (D) 資源共享的技術問題
A	45. 使用雲端架設的 HTTP 服務時，若伺服器無法找到相對應的檔案，會回覆下列何種代碼？ (A) 404 (B) 200

108 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：108 年 12 月 07 日

第 9 頁，共 9 頁

	(C) 500 (D) 304
D	46. 為確保手機安全性及方便管理，許多公司使用 MDM 的軟體或平台，用來限制手機功能或提供遠端資料抹除能力，請問 MDM 的全名為下列何者？ (A) Mobile Data Management (B) Mobile Device Motion (C) Mobile Design and Manufacturing (D) Mobile Device Management
B	47. 關於使用行動裝置的行為，下列敘述何者較「不」恰當？ (A) 下載應用程式只選擇可信任的來源，如：Apple Store、Google Play (B) 使用免費的公共無線網路服務，可確保行動裝置不會被駭 (C) 當收到訊息中含有連結網址時，仍要提防是否有危險性 (D) 在行動裝置中要安裝防毒軟體並定期的去更新
D	48. 關於行動裝置上運用代碼技術（Tokenization）行動支付方式的安全，下列敘述何者正確？ (A) 運用手機本身的 Secure Element 儲存 Tokenization 是不安全的 (B) 信用卡號會儲存在手機本身，故手機遺失時相當危險 (C) 自行破解並取得手機所有權限來管理最安全 (D) 代碼就算被取得也無法知道使用者原本的卡號
D	49. 在物聯網裡，駭客可能會竊走設備間傳輸的資料，竄改之後再傳送給另外一方，這是屬於下列何種攻擊手法？ (A) 密碼攻擊（Password-Based Attack） (B) 金鑰淪陷攻擊（Compromised-Key Attack） (C) 阻斷服務攻擊（Denial-of-Service Attack） (D) 中間人攻擊（Man-in-the-Middle Attack）
C	50. 下列何種機制對於增加物聯網安全「沒有」幫助？ (A) 啟用設備的安全功能 (B) 定期檢查設備系統更新 (C) 啟用多種連線方式 (D) 使用足夠安全的密碼